



Práctica SonarQube

Nombre: Guillermo Larzen Vazquez Rangel

Grupo: IDGS17

Matricula: 2024171016

Maestro: Gerardo Ramírez Villarreal

Materia: Seguridad en el Desarrollo de Aplicaciones

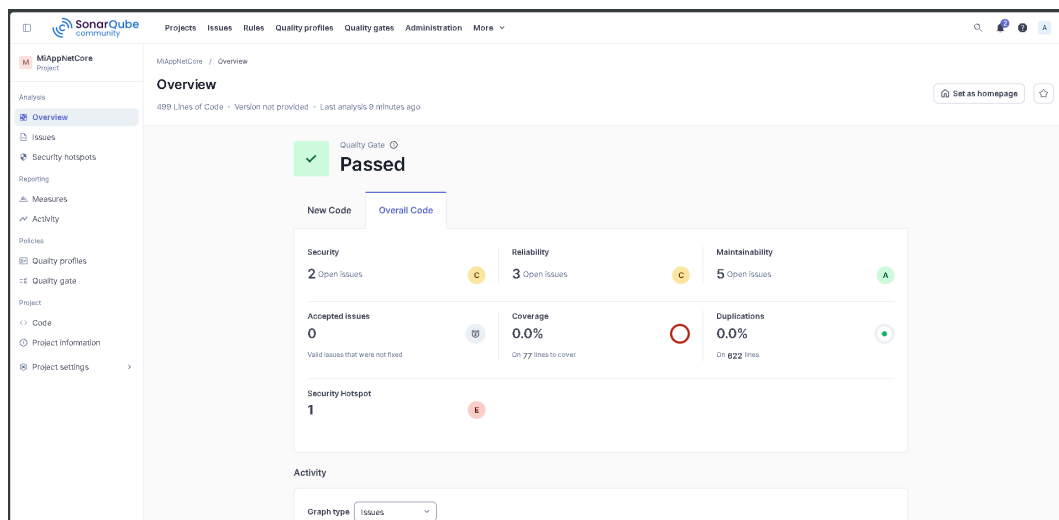
Índice

1. Hallazgos Identificados	3
2. Correcciones Realizadas	4
3. Ejecución de Comandos	7
4. Preguntas de Reflexión	8
6. SonarCube Token	9

1. Hallazgos Identificados

Después del análisis inicial, se identificaron siete vulnerabilidades:

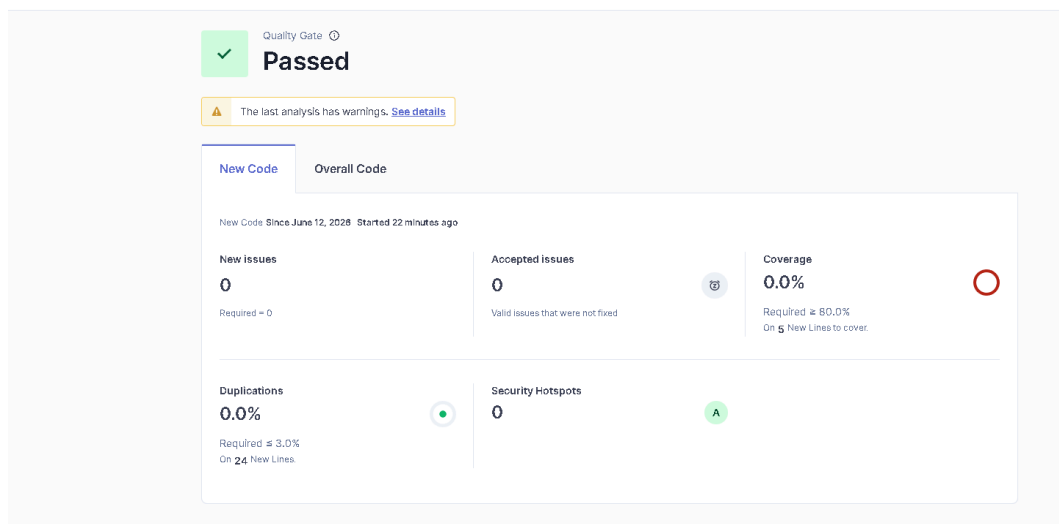
- **Inyección SQL:** Se encontró concatenación directa de variables o declaraciones SQL explícitas, permitiendo la manipulación de datos.
- **Credenciales *hardcoded*:** Se encontró la palabra "password", algo explícitamente contrario a las normas de seguridad.
- **Deuda técnica (*Maintainability*):** Se identificaron variables no utilizadas, duplicidad en selectores CSS y el uso de métodos síncronos obsoletos (como .Run()) en lugar de sus contrapartes asíncronas.



MiAppNetCore / Overview

Overview

503 Lines of Code • Version not provided • Last analysis 2 minutes ago



2. Correcciones Realizadas

Se aplicaron las siguientes medidas correctivas para elevar el nivel de seguridad y mantenibilidad de la aplicación:

Hallazgo	Acción Correctiva
Inyección SQL	Se implementaron consultas parametrizadas en AuthController.cs usando EF Core.
Credenciales <i>hardcoded</i>	Se renombraron las propiedades sensibles a P_key y se eliminaron los literales comprometedores.
Inconsistencias CSS	Se eliminaron los selectores duplicados en site.css.
Problemas de rendimiento	Se sustituyó app.Run() por await app.RunAsync() en Program.cs.

```

35 app.UseHttpsRedirection();
36 app.UseStaticFiles();
37 app.UseRouting();
38
39 app.UseSession();
40 app.UseAuthorization();
41
42 app.MapControllerRoute(
43     name: "default",
44     pattern: "{controller=Home}/{action=Index}/{id?}");
45
46 app.Run();
47

```

```

35 app.UseHttpsRedirection();
36 app.UseStaticFiles();
37 app.UseRouting();
38
39 app.UseSession();
40 app.UseAuthorization();
41
42 app.MapControllerRoute(
43     name: "default",
44     pattern: "{controller=Home}/{action=Index}/{id?}");
45
46+ await app.RunAsync(); You, 4 minutes ago • Uncommitted ch
47

```

```

wwwroot > css > # site.css > btn:focus
1  html {
2  |  font-size: 14px;
3  }
4
5  @media (min-width: 768px) {
6  |  html {
7  |  |  font-size: 16px;
8  |  }
9  }
10
11+ .btn:focus, .btn.active:focus, .btn-link,
12+ nav-link:focus, .form-control:focus, .
13+ form-check-input:focus {
14+
15+
16+ box-shadow: 0 0 0 0.1rem white, 0 0 0 0.25rem
17+ #258cfb;
18+
19+ }
20
21 html {
22
23 position: relative;
24 min-height: 100%;
25 }
26
27 body {
28 |  margin-bottom: 60px;
29 }
30
31+ .form-floating > .form-control-plaintext::placeholder, .
32+ form-floating > .form-control::placeholder {
33+ |  color: var(--bs-secondary-color);
34+ |  text-align: end;
35+ }
36
37+ .form-floating > .
38+ form-control-plaintext:focus::placeholder, .
39+ form-floating > .form-control:focus::placeholder {
40+ |  text-align: start;
41+ }

```

```

1  html {
2  |  font-size: 14px;
3  }
4
5  @media (min-width: 768px) {
6  |  html {
7  |  |  font-size: 16px;
8  |  }
9  }
10
11+ .btn:focus, You, 17 minutes ago • Uncommitted changes
12+ .btn.active:focus,
13+ .btn-link, nav-link:focus,
14+ .form-control:focus,
15+ .form-check-input:focus {
16+ |  box-shadow:
17+ |  |  0 0 0 0.1rem white,
18+ |  |  0 0 0 0.25rem #258cfb;
19+ }
20
21 html {
22+ |  font-size: 14px; /* Mueve aquí el tamaño base */
23 |  position: relative;
24 |  min-height: 100%;
25 }
26
27 body {
28 |  margin-bottom: 60px;
29 }
30
31+ .form-floating > .form-control-plaintext::placeholder,
32+ .form-floating > .form-control::placeholder {
33+ |  color: var(--bs-secondary-color);
34+ |  text-align: end;
35+ }
36
37+ .form-floating > .form-control-plaintext:focus::placeholder,
38+ .form-floating > .form-control:focus::placeholder {
39+ |  text-align: start;
40+ }
41+

```

```

..... .FromSqlRaw("SELECT * FROM Users WHERE
      Username = {0} AND Password = {1}",
      username, password)
..... .FirstOrDefault();

```

```
Help  →  VulnerableApp  [?]  Sign In

# Users.cs M  # AppDbContext.cs M  # Program.cs M  # AuthController.cs (Working Tree)  # AppDbContext.cs (Working Tree)  # site.css M  [?]  [?]  [?]  [?]  [?]  [?]

Data >  # AppDbContext.cs >  VulnerableApp.Data >  AppDbContext >  OnModelCreating(ModelBuilder) : void

1  using Microsoft.EntityFrameworkCore;
2  using VulnerableApp.Models;
3  namespace VulnerableApp.Data
4  {
5      public class AppDbContext : DbContext
6      {
7          public AppDbContext(
8              DbContextOptions<AppDbContext> options) : base
9              (options) {}
10
11         public DbSet<User> Users { get; set; }
12
13         protected override void OnModelCreating
14             (ModelBuilder modelBuilder)
15         {
16             // Definir precisión para el tipo decimal
17             modelBuilder.Entity<User>().Property(u => u.
18                 Balance).HasPrecision(18, 2);
19
20             modelBuilder.Entity<User>().HasData(
21                 new User { Id = 1, Username = "admin",
22                     PasswordHash = "admin", Email = "admin@test.
23                     com", Balance = 1000m, CreatedAt = new DateTime
24                     (2026, 1, 1) },
25                 new User { Id = 2, Username = "user1",
26                     PasswordHash = "123456", Email = "user@test.
27                     com", Balance = 500m, CreatedAt = new DateTime
28                     (2026, 1, 1) },
29                 new User { Id = 3, Username = "user2",
30                     PasswordHash = "PasswordHash", Email =
31                     "user2@test.com", Balance = 750m, CreatedAt =
32                     new DateTime(2026, 1, 1) }
33             );
34         }
35     }
36 }
```

3. Ejecución de Comandos

El flujo de trabajo se realizó desde una terminal Git Bash en Windows, ejecutando los siguientes pasos de forma secuencial:

1. **BEGIN:** `dotnet sonarscanner begin -k:"MiAppNetCore" -d:"sonar.host.url=http://localhost:9000" -d:"sonar.token=$SONAR_TOKEN" -d:"sonar.cs.opencover.reportsPaths=/coverage.opencover.xml" -d:"sonar.cs.vstest.reportsPaths=/*.trx"`
2. **BUILD:** `dotnet build --no-incremental`
3. **TEST:** `dotnet test --collect:"XPlat Code Coverage" --settings DataCollectionRunSettings.DataCollectors.DataCollector.Configuration.Format=opencover`
4. **END:** `dotnet sonarscanner end -d:"sonar.token=$SONAR_TOKEN"`

```
Windows[DESKTOP-HUGDQSV] MINGW64 ~/Documents/VulnerableApp (secure)
$
Windows[DESKTOP-HUGDQSV] MINGW64 ~/Documents/VulnerableApp (secure)
$ dotnet sonarscanner begin -k:"MiAppNetCore" -d:"sonar.host.url=http://localhost:9000" -d:"sonar.token=$SONAR_TOKEN" -d:"sonar.cs.opencover.reportsPaths=/coverage.opencover.xml" -d:"sonar.cs.vstest.reportsPaths=/*.trx"
SonarScanner for .NET 11.2.1
Using the .NET Core version of the Scanner for .NET
Pre-processing started.
Preparing working directories...
16:42:04.985 Updating build integration targets...
16:42:05.169 Using SonarQube v26.6.0.122539.
16:42:05.436 Fetching analysis configuration settings...
16:42:06.151 Provisioning analyzer assemblies for cs...
16:42:06.153 Installing required Roslyn analyzers...
16:42:06.155 Processing plugin: csharp version 10.27.0.148913
16:42:06.641 Provisioning analyzer assemblies for vnet...
16:42:06.643 Installing required Roslyn analyzers...
16:42:06.644 Processing plugin: vnet version 10.27.0.148913
16:42:06.656 Incremental PR analysis: Base branch parameter was not provided.
16:42:06.658 Cache data is empty. A full analysis will be performed.
16:42:06.734 Pre-processing succeeded.

Windows[DESKTOP-HUGDQSV] MINGW64 ~/Documents/VulnerableApp (secure)
$ dotnet build --no-incremental
Restauración completada (0.8s)
  VulnerableApp net10.0 realizado correctamente (3.8s) → bin(Debug|net10.0|VulnerableApp.dll

Compilación realizado correctamente en 5.6s

Windows[DESKTOP-HUGDQSV] MINGW64 ~/Documents/VulnerableApp (secure)
$ dotnet test --collect:"XPlat Code Coverage" --settings DataCollectionRunSettings.DataCollectors.DataCollector.Configuration.Format=opencover
Restauración completada (0.7s)

Compilación realizado correctamente en 1.8s
```

4. Preguntas de Reflexión

1. ¿Qué diferencia hay entre un Security Hotspot y un Bug en SonarQube?

Un *Bug* es un error en la lógica del funcionamiento que debe corregirse, y un *Hotspot* es un punto de riesgo que requiere evaluación humana para decidir si es necesario aplicar una medida de mitigación.

2. ¿Por qué es inseguro concatenar directamente el input del usuario en una query SQL? Explica el ataque con un ejemplo de payload.

Es inseguro porque permite que un usuario con intenciones no deseadas salga del uso esperado mediante diversos caracteres, pudiendo ejecutar comandos directamente para la edición y obtención de datos SQL. Un ejemplo de *payload* sería ' OR '1'='1', que engaña a la base de datos para devolver información sin validar credenciales.

3. ¿Qué es el Code Coverage y por qué SonarQube lo considera relevante para la seguridad?

Es una métrica de validación. Un 0% de cobertura indica que no se han ejecutado pruebas unitarias sobre el código, dejando "puntos ciegos" donde existen vulnerabilidades críticas que no han sido probadas.

4. Si un colega sube el token de SonarQube a GitHub por error, ¿qué pasos seguirías para mitigar el riesgo?

El procedimiento estándar es la revocación inmediata del token en la plataforma y la limpieza del historial de versiones (Git) para prevenir accesos no autorizados.

5. ¿Cómo integrarías SonarQube en un pipeline CI/CD de GitHub Actions? Describe los pasos a alto nivel.

La automatización permite "Shift-Left Security", integrando la seguridad desde las primeras etapas del desarrollo. Los pasos a alto nivel son: configurar el archivo de *workflow* en GitHub Actions, definir los secretos del token de SonarQube, ejecutar el escaneo mediante los comandos de inicio (*begin*), compilación, pruebas y finalización (*end*), asegurando que cada *commit* cumpla con los estándares mínimos.

6. SonarCube Token

```
C# User.cs M C# AppDbContext.cs M C# Program.cs M C# AuthController.cs (Working Tree) M # site.css M
1  sqp_9f18ca3e658a06f4f045205f0569ae2d9f6e22f0_
```

Huesos@DESKTOP-HLGDDSV MINGW64 ~/Documents/VulnerableApp (secure)

\$ echo \$SONAR_TOKEN

sqp_9f18ca3e658a06f4f045205f0569ae2d9f6e22f0

Huesos@DESKTOP-HLGDDSV MINGW64 ~/Documents/VulnerableApp (secure)

\$